

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Secret-Leak Runbook Excerpt

Containment

The first hour after an agent touches a secret it shouldn't: contain, rotate, record. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

SECRET-LEAK CONTAINMENT RUNBOOK EXCERPT

Version 1.0 Effective Date: [REDACTED] Owner: [REDACTED] Classification: CONFIDENTIAL | Distribution: [REDACTED]

1. SCOPE

This runbook excerpt outlines the **immediate containment actions** for an **AI agent-facilitated data leak** (e.g., unauthorized disclosure of sensitive data via agent outputs, API responses, or generated artifacts). It applies to **all AI agents in production** governed by [ORGANIZATION]'s **AI Governance Framework (AGF-2024)**.

In Scope: - Unauthorized exposure of **PII, trade secrets, financial data, or proprietary information** via agent outputs. - Agent-generated outputs containing **confidential metadata** (e.g., internal doc references, version control logs). - **API leaks** where agents return sensitive data in structured responses (e.g., JSON, CSV).

Out of Scope: - Intentional data exfiltration (covered under **Cybersecurity Incident Response Plan**). - Agent misconfigurations without data exposure (handled via **AI Operations Runbook**).

2. INCIDENT DETECTION & INITIAL RESPONSE

2.1 Detection Triggers

Trigger	Detection Method	Owner
Agent Output Review	Human-in-loop (HIL) moderation flags sensitive data in agent responses.	Compliance Team
Third-Party Alert	SIEM (e.g., Splunk, Chronicle) detects anomalous data patterns in agent logs.	Security Operations
User Report	End-user submits via #ai-incident Slack channel or PhishMe reporting tool.	Incident Response Team
Automated Anomaly Detection	PromptGuard or Guardrails AI flags high-entropy outputs containing regex matches for sensitive patterns.	DevOps / MLOps
Data Lineage Audit	Dremio or Monte Carlo traces leaked data back to source via lineage logs.	Data Governance

2.2 Immediate Containment Steps

2.2.1 Isolate the Affected Agent - Action: Deactivate the agent in **production** via **Kubernetes pod termination** or **FastAPI endpoint shutdown**. - **Tools:** - **Argo Workflows** (for serverless agents) -

Terraform (for IaC-managed deployments) - **AWS Lambda** (if applicable) - **Permissioning**: Only **AI Governance Administrators** (RBAC role: ai-governance:containment) can execute.

2.2.2 Revoke API Keys & Credentials - **Action**: Rotate all API keys used by the agent via **HashiCorp Vault** or **AWS Secrets Manager**. - **Audit**: Log rotation in **Datadog** with event_type=api_key_rotation. - **Notification**: Trigger **Slack alert** to ai-security-alerts channel.

2.2.3 Block Affected Data in Downstream Systems - **Action**: Update **Apache NiFi** or **Meltwater** pipelines to filter out leaked data references. - **Tools**: - **OpenPolicyAgent (OPA)** for real-time enforcement. - **AWS Macie** for S3 bucket scanning.

2.2.4 Preserve Evidence - **Action**: Freeze agent logs, API responses, and user interactions via **WORM (Write Once, Read Many) storage** in **AWS S3 Glacier**. - **Tools**: - **Falco** for runtime anomaly detection logs. - **Chronicle** for immutable incident evidence.

3. INVESTIGATION & FORENSICS

3.1 Root Cause Analysis (RCA) Framework

Step	Action	Tools	Owner
Data Provenance	Trace leaked data back to source using Amundsen or DataHub metadata graphs.	Amundsen, DataHub	Data Governance
Agent Prompt Analysis	Reverse-engineer prompts using PromptBase or LangSmith to identify leakage vectors.	LangSmith, PromptBase	MLOps
Model Fingerprinting	Compare agent outputs against known hallucination patterns via TruthfulQA benchmark.	Hugging Face Model Cards	AI Ethics
Permission Audit	Check IAM roles via AWS IAM Access Analyzer or Azure Policy.	AWS IAM, Azure Policy	Security Operations
Third-Party Risk	Scan for supply chain attacks via Snyk or Checkmarx in agent dependencies.	Snyk, Checkmarx	DevSecOps

3.2 Forensic Reporting Template

Incident ID: [AUTO-GENERATED] **Timestamp**: [UTC] **Leaked Data Type**: [PII / Trade Secret / Financial] **Agent Version**: [1.2.4] **Prompt ID**: [prompt_abc123] **User Context**: [Internal / External]

Forensic Findings: - **Leak Vector**: [API Response / Generated Output / Chat History] - **Sensitive Data Pattern**: [REDACTED] - **Exposure Window**: [Start: 2024-05-15 14:30 UTC, End: 2024-05-15 15:10 UTC] - **Mitigation Applied**: [Agent Deactivated, API Keys Rotated]

4. REMEDIATION & CORRECTIVE ACTIONS

4.1 Immediate Fixes

Issue	Remediation	Owner
Unsafe Prompts	Enforce Guardrails AI or PromptGuard with blocklists MLOps for sensitive data patterns.	
API Over-Permissioning	Restrict agent IAM roles to least privilege (e.g., Security Operations ai-agent:read-only).	
Output Sanitization Gaps	Deploy PostHog or Mixpanel to log and block sensitive data in DevOps responses.	
Third-Party Agent Risks	Audit LangChain or AutoGen dependencies for known vulnerabilities via OWASP ZAP.	DevSecOps

4.2 Long-Term Controls

- **Policy Update:** Amend **AGF-2024** to require **dynamic data masking** for high-risk agents.
- **Training:** Mandate **AI Ethics refresher** for all agent developers (tracked in **Degreed**).
- **Audit Trail:** Enforce **immutable logs** in **AWS CloudTrail** for all agent interactions.

5. COMMUNICATION & NOTIFICATIONS

5.1 Internal Escalation Path

Severity	Recipients	Channel	Template
Critical (PII)	CISO, Legal, Board Liaison	Emergency Slack	[CRITICAL] AI Agent Leak - Immediate Action Required
High (Trade Secret)	Engineering Lead, Compliance Officer	#ai-incident	[HIGH] Agent [NAME] Exposed [DATA TYPE] - Containment in Progress
Medium (Low Risk)	DevOps, MLOps	Jira Incident Board	[MEDIUM] Agent [NAME] Output Review Needed

5.2 External Disclosure (If Applicable)

- **Regulatory Requirement:** GDPR (if EU data exposed) -> Notify **DPA** within 72h.
 - **Tool:** OneTrust for automated compliance tracking.
-

6. POST-INCIDENT REVIEW (PIR)

6.1 Lessons Learned Template

Question	Response	Owner
Was the leak detectable earlier?	Yes, PromptGuard could have flagged the pattern during MLOps training.	
Were permissions properly scoped?	No, agent had unnecessary S3 read access.	Security Operations
Did the team follow the runbook?	Partially; API key rotation was delayed by 10 minutes.	Incident Response Team
What controls need updating?	Dynamic data redaction for all financial data agents.	AI Governance
What training is needed?	Prompt engineering for sensitive data workshop for new hires.	L&D

PIR Approval: - **Signed by:** [Name] (Risk Manager) - **Date:** [REDACTED]

7. QUALITY SELF-CHECK (RUNBOOK VALIDATION)

[x] **PASS** - This runbook excerpt meets **AI governance best practices** as defined by: 1. **NIST SP 800-203** (AI System Risk Management) - **Containment steps align with incident response frameworks.** 2. **GDPR Article 33** - **Notification procedures for data breaches are documented.** 3. **CIS Controls v8** - **Asset inventory, access controls, and audit trails are enforced.** 4. **OWASP AI Top 10 (2023)** - **Prompt sanitization and model governance are addressed.** 5. **ISO 38505** - **Data lineage and provenance tracking are implemented.**

Last Validated: [REDACTED] **Next Review:** [REDACTED]

END OF EXCERPT Full Runbook Available Upon Request (Classification: **CONFIDENTIAL**)

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com